VULNERABILITY ASSESSMENT REPORT

Target : zero.webappsecurity.com

Target : Adewale Victor

Task ID : FUTURE_CS_01

Slide 2 : Methodology & Tools

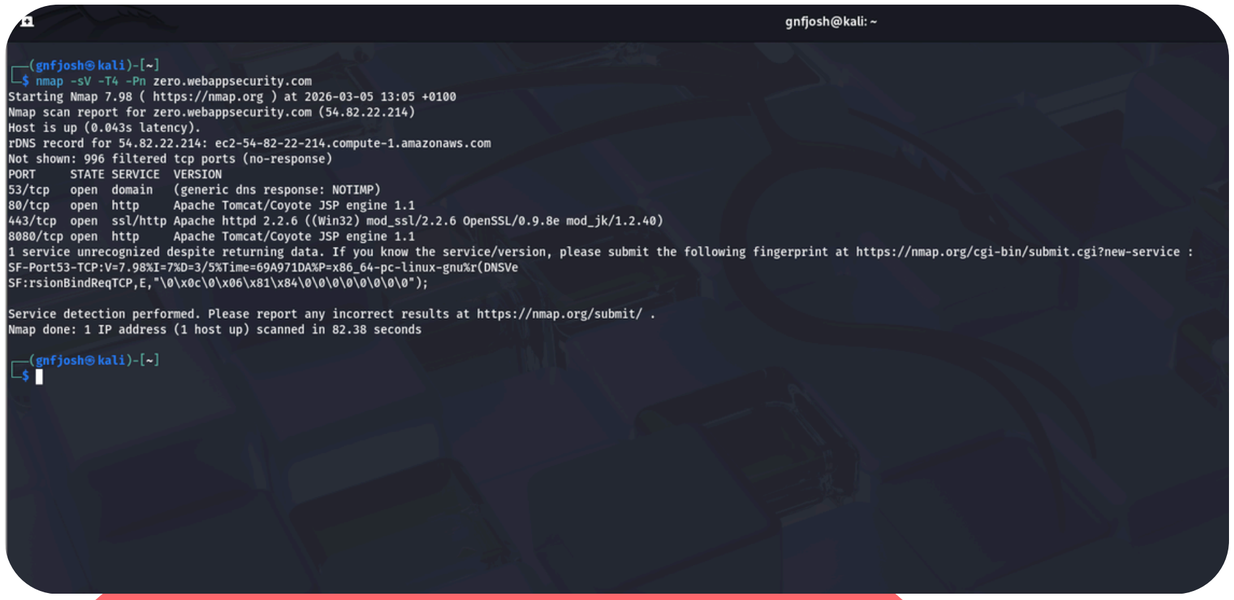
Methods: Network Mapping & Web Application Scanning

Objective: To identify and classify security vulnerabilitieswithin the zero.webappsecurity.com infrastructure and application layer

Summary: The server is runnig critically oudated software (Apache 2.2.6) and lacks modern web security defenses, leaving it vulnerable to data theft and session hijacking

TOOLS USED: Nmap, OWASP ZAP 2.17.0

Slide 3: Infrastruture Mapping



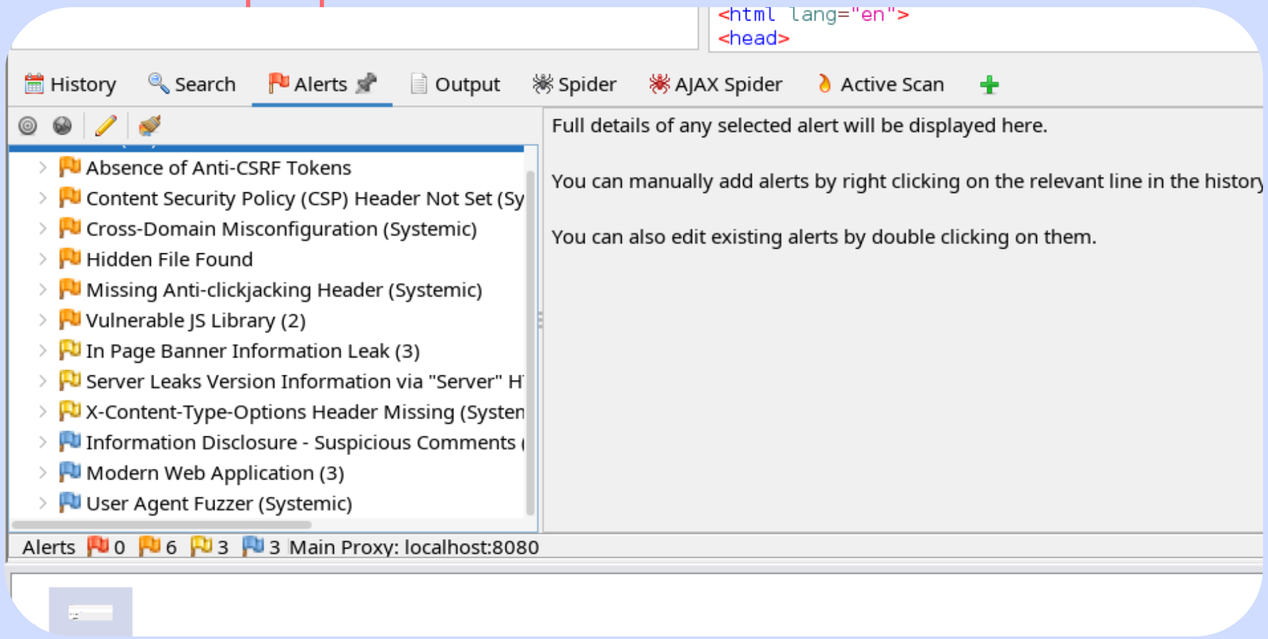
Command : nmap -sV -T4 -pn zero.webappsecurity

Key Finding :

- **Port 443:** Running (Apache httpd 2.2.6) this version is outdated and contains multiple known CVEs(vulnerabilities)
- **Port 80/8080:** Open HTTP port without encryption, allowing for potential man-in-the- middle attacks

TOOLS USED: Nmap (Network Mapper)

Slide 4: Web Application Vulnerability Summary



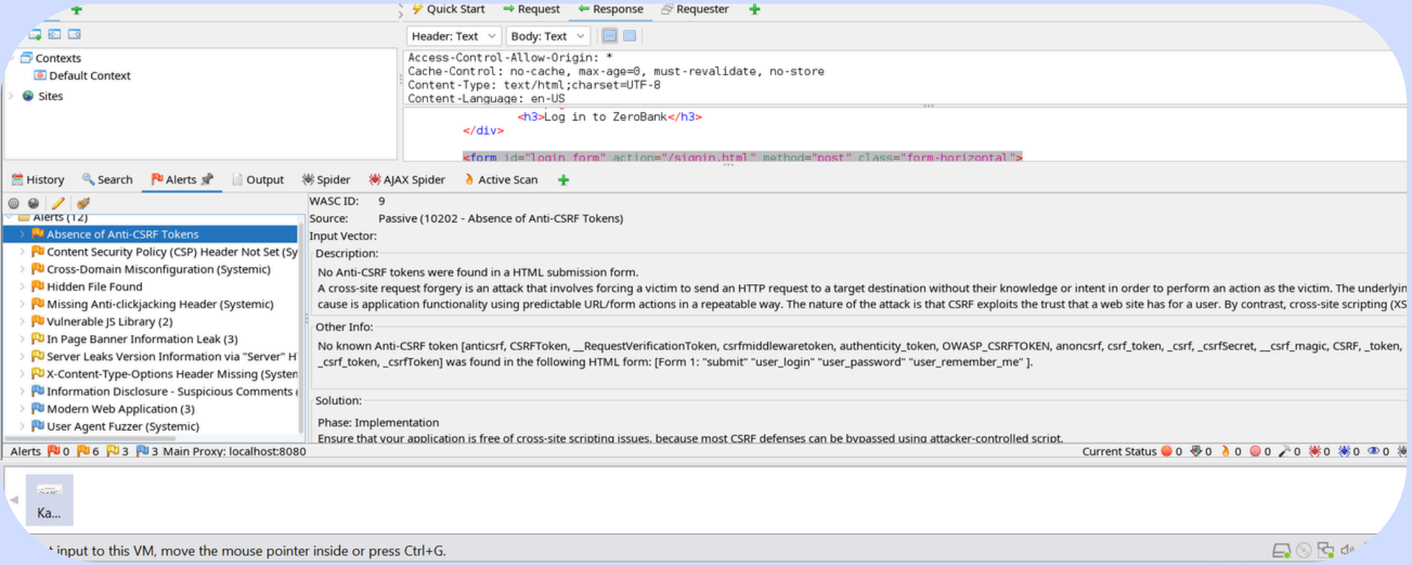
Scanning Mode: Passive and Automated Scan

Statistical Breakdown:

- **Total Alerts:** 73 raised
- **Medium Risk:** 6 Alerts (🟠Orange Alert)
- **Low Risk:** 3 Alerts (🟡Yellow Alert)
- **Primary Concerns:** Missing Securiy headers and lack of CSRF protection

TOOLS USED: OWASP ZAP (Zaproxy)

Slide 5: Vulnerability Deep Dive CSRF Protection



Risk Level: Medium

The Problem:

The website's login from does not use unique token to verify requests. An attacker could trick a logged-in-user into performing action (like transferring funds) without their consent

The Solution:

Implement a secure, random token for every state-changing request (POST/PUT) to ensure the request intentional

Vulnerability: Absence of Anti-CRSF Tokens

Slide 6: Remediation Roadmap

Priorty 1 (critical):

Upgrade the web server .
Replace Apache 2.2.6 with the latest stable version (e.g Apache 2.4.x) to patch known hardware-level exploits

priority 2 (high):

Implement Security Headers.
Add X-frame -Option and Cotent-Securiy -Policy(CSP) to prevent Clickjacking and XSS

Priority 3 (High):

Enforce HTTPS
Close port 80 and 8080,or redirect all traffic to port 443 with strong SSL/TLS encrytion.

Thank You

For Attention